

GUÍA METODOLÓGICA DETALLADA DE APLICACIÓN Y ANÁLISIS

Protocolo Exhaustivo para Administración, Análisis y Reporte de Encuesta de Ciberseguridad

Versión: 1.0

Fecha: Enero 2026

Público: CISOs, Analistas de seguridad, Auditores, Consultores

Propósito: Manual operacional para ejecutar encuesta integral (10-12 semanas) con máximo rigor

PARTE 1: PROTOCOLO DE ADMINISTRACIÓN (SEMANAS 1-5)

Fase 0: Preparación (Semanas 1-2)

Paso 0.1: Obtener Aprobación Ejecutiva

Reunión con Sponsor Ejecutivo (CFO/C00/Board):

AGENDA (30 min):

- Objetivo: ¿Por qué medimos madurez de ciberseguridad?
- Alcance: ¿A quién encuestamos? (líderes, equipo completo, muestra?)
- Presupuesto: ¿Cuánto cuesta? (herramientas, tiempo, consultores?)
- Timeline: ¿Cuándo? (8-12 semanas)
- Uso de resultados: ¿Qué hacemos con los datos?
- Confidencialidad: ¿Anónimo o identificado?

REQUERIMIENTOS:

- ✓ Aprobación formal (email o acta)
- ✓ Presupuesto asignado
- ✓ Sponsor designado
- ✓ Calendario publicado

Paso 0.2: Crear Equipo de Proyecto

EQUIPO MÍNIMO:

Propietario (1 persona):

- └ CISO o Director de Seguridad
 - Responsable de cronograma
 - Escalaciones
 - Resultados finales

Ejecutor Técnico (1-2 personas):

- └ Security Manager / Analyst
 - Administra encuesta (distribución, recordatorios)
 - Recopila respuestas
 - Valida datos

Analista (1 persona):

- └ Data analyst / Risk manager
 - Ingresa datos en Excel
 - Calcula IGM
 - Prepara gráficos

Comunicador (0.5 personas):

- └ Puede ser CISO o assistant
 - Envía comunicaciones
 - FAQ
 - Sesiones de calibración

TOTAL DEDICACIÓN: ~60-80 horas en 12 semanas (~5-7 hrs/semana)

Paso 0.3: Seleccionar Plataforma de Encuesta

OPCIONES (ordenadas por recomendación):

OPCIÓN 1: Microsoft Forms (RECOMENDADO para pymes)

- Costo: GRATIS (incluido Office 365)
- Configuración: <2 horas
- Capacidad: >5000 respuestas
- Análisis: Gráficos automáticos básicos
- Exportación: Excel nativa
- Recomendación: MEJOR costo-beneficio

OPCIÓN 2: Google Forms (RECOMENDADO para distribuido)

- Costo: GRATIS
- Configuración: <2 horas
- Capacidad: Ilimitada
- Análisis: Gráficos automáticos
- Exportación: Google Sheets
- Recomendación: Mejor para mobile/remoto

OPCIÓN 3: Qualtrics / SurveyMonkey (Para empresa grande)

- Costo: €50-500/mes
- Configuración: 1 semana
- Capacidad: Ilimitada
- Análisis: ML/AI avanzado
- Exportación: Completa
- Recomendación: Si presupuesto >€20k

DECISIÓN RECOMENDADA: Microsoft Forms (balance óptimo)

Paso 0.4: Adaptar Encuesta Base

PERSONALIZACIÓN REQUIERE (4-8 horas):

1. Logo organizacional (portada)
2. Instrucciones específicas (ajustar a contexto)
3. Nombre de tu organización (referencias)
4. Sector específico (si needed: añadir preguntas sector)
5. Regulaciones aplicables (enfaticar en introducción)

HERRAMIENTA: Usar Microsoft Word

- Copiar texto de Documento A (Encuesta Integral)
- Personalizar en plantilla corporativa
- Exportar a PDF (para lectura)
- Importar preguntas a Microsoft Forms (copiar-pegar)

Fase 1: Distribución y Recopilación (Semanas 3-5)

Paso 1.1: Identificar Respondentes

CRITERIO DE SELECCIÓN:

Deben responder (OBLIGATORIO):

- CISO / Head of Security
- Security Manager (por module/área)
- IT Manager / Infrastructure
- Compliance Officer
- Risk Manager
- CIO / IT Director
- Total: Mínimo 5-7 personas (PYME) a 15-20 (Empresa)

BENEFICIO DE MÚLTIPLES RESPONDENTES:

- ✓ Valida perspectivas diferentes
- ✓ Reduce sesgo de una persona
- ✓ Calibración más robusta
- ✓ Mejor aceptación de resultados

NOTA: NO encuestar a todo el personal (es largo)

Encuestar solo líderes y responsables de cada área

Paso 1.2: Enviar Email de Lanzamiento

ASUNTO: "Encuesta de Evaluación de Madurez Ciberseguridad - Tu Participación"

CONTENIDO (tono según Documento C - Narrativa):

Estimado [Nombre],

La ciberseguridad es como mantener una casa: no es cuestión de si entrará alguien indeseado, sino de cuándo... y cuán preparados estamos.

Estamos realizando una evaluación exhaustiva de madurez de ciberseguridad en [Nombre Empresa] para saber dónde estamos hoy y a dónde queremos llegar.

DETALLES:

- └ Duración: 45-60 minutos
- └ Preguntas: 140+ en escala 1-5 (sin preguntas "correctas" o "incorrectas")
- └ Plazo: [Fecha límite en 7 días]
- └ Confidencialidad: [Anónima / Identificada - según política]
- └ Link: [URL a Microsoft Forms]

POR QUÉ TE PEDIMOS:

Tú, como [responsable de AREA], eres experto en [DOMINIO].
Sin tu perspectiva honesta, nuestra evaluación sería incompleta.

NO ES UN EXAMEN DE "CULPA":

- └ Puntuación baja (Nivel 1) = "oportunidad de mejora"
- └ Puntuación alta (Nivel 5) = "liderazgo demostrado"
- └ El objetivo es mejorar, no castigar

PREGUNTAS:

Responde FAQ.txt [adjunto] o contacta [email CISO]

Gracias por tu honestidad.

[Firma CISO]

Paso 1.3: Recordatorios Automáticos

CRONOGRAMA DE RECORDATORIOS:

Día 0 (Lunes): Email inicial + link encuesta
Día 3 (Jueves): Recordatorio 1 ("quedan 4 días")
Día 6 (Domingo): Recordatorio 2 ("quedan 1 día")
Día 7 (Lunes): Recordatorio Final 3 ("hoy es el último día")
Día 8: Cierre de encuesta

META: 80-90% completion en 7-10 días

SI <60% COMPLETION:

- └ Contacto personal 1-a-1 con respondentes clave
Llamada de 5 min: "¿Hay obstáculo? ¿Cómo te ayudo?"

Paso 1.4: Sesiones de Calibración (CRÍTICO)

PROPÓSITO:

Asegurar que "Nivel 3" significa lo mismo para todos.
Sin calibración, resultados serán inconsistentes.

ESTRUCTURA:

Sesión 1: GRC, IDENTIFY, IAM (2 horas)

- └ Responsables CISO, IT, Compliance
- └ Revisar respuestas preliminares
- └ Discutir discrepancias
- └ Ajustar scores con consenso
- └ Documentar decisiones

Sesión 2: PROTECT, DETECT, RESPOND (2 horas)

- └ Responsables SOC, Infraestructura
- └ Mismo proceso
- └ Focus: evidencia observable

Sesión 3: RECOVER, AWARENESS, SCRM (1.5 horas)

- └ Responsables BCP, HR, Procurement
- └ Validar scores finales
- └ Preparación para análisis

TOTAL: 5.5 horas (1 día completo o 2 half-days)

MÉTODO:

1. Proyectar respuesta en pantalla
2. Leer descripción de Nivel 1-5
3. Preguntar: "¿Dónde caemos exactamente?"
4. Evidencia: "¿Qué prueba tienes?"
5. Consenso: Anotar scoring final
6. Justificación: Documentar por qué ese nivel

PARTE 2: ANÁLISIS DE DATOS (SEMANA 6)

Paso 2.1: Exportar y Validar Datos

PROCEDIMIENTO:

1. Descargar respuestas de Microsoft Forms
 - └ Opción: "Abierto en Excel" (automático)
2. Validar datos
 - └ Verificar que no hay blancos (todas preguntas respondidas)
 - └ Verificar que scores están en rango 1-5
 - └ Identificar outliers (si alguien puso 5 en TODO)
 - └ Nota: Outliers son normales; documentar pero incluir
3. Crear hoja de consolidación
 - └ Columna A: Preguntas (GRC.1, GRC.2, ... SCRM.15)
 - └ Columnas B-J: Respuestas de cada respondente
 - └ Columna K: PROMEDIO de respuesta
 - └ Colorear con semáforo (rojo <2, amarillo 2-3, verde >3)

Paso 2.2: Calcular IGM (Índice Global de Madurez)

FÓRMULA IGM:

$$\text{IGM} = (\text{Suma de todos promedio_módulo}) / 9 \times (100/5)$$

Desglosado:

1. Calcular promedio por MÓDULO:
 $\text{GRC_promedio} = (\text{GRC.1} + \text{GRC.2} + \dots + \text{GRC.18}) / 18$
 $\text{IDENTIFY_promedio} = (\text{IDENTIFY.1} + \dots + \text{IDENTIFY.20}) / 20$
[etc. para todos 9 módulos]
2. Calcular promedio GLOBAL:
 $\text{IGM_decimal} = (\text{GRC_prom} + \text{IDENTIFY_prom} + \dots + \text{SCRM_prom}) / 9$
3. Convertir a escala 0-100%:
 $\text{IGM_porcentaje} = \text{IGM_decimal} / 5 \times 100$

EJEMPLO:

GRC_promedio:	2.8
IDENTIFY_promedio:	2.5
IAM_promedio:	3.1
PROTECT_promedio:	2.3
DETECT_promedio:	2.0
RESPOND_promedio:	2.6
RECOVER_promedio:	2.7
AWARENESS_promedio:	2.4
SCRM_promedio:	2.2

Promedio global: 2.53

$$\text{IGM} = 2.53 / 5 \times 100 = 50.6\%$$

INTERPRETACIÓN: IGM 50.6% = Nivel ACEPTABLE (objetivo mejora)

Paso 2.3: Análisis Detallado por Módulo

MATRIZ DE DESGLOSE:

Módulo	Promedio	Evaluación	Riesgos Detectados
GRC	2.8	Bueno	Política desactualizada
IDENTIFY	2.5	Aceptable	Inventario <70% cobertura
IAM	3.1	Bueno	MFA no en 100% admin
PROTECT	2.3	Débil	Parcheo >30 días; gaps
DETECT	2.0	Crítico	SIEM muy lento (MTTD >14d)
RESPOND	2.6	Aceptable	Plan existe, MTTR es alto
RECOVER	2.7	Aceptable	Backups OK, RTO no probado
AWARENESS	2.4	Aceptable	Phishing 8% clic rate
SCRM	2.2	Débil	Solo 60% proveedores eval

ÁREAS CRÍTICAS (Promedio <2.5):

1. DETECT (2.0) - Requiere acción inmediata
2. SCRM (2.2) - NIS2 compliance en riesgo
3. PROTECT (2.3) - Vulnerabilidades críticas
4. AWARENESS (2.4) - Conciencia insuficiente

PLAN DE ACCIÓN PRIORITARIO:

1. Mejorar SIEM/MTTD (DETECT) - €50k, 8 semanas
2. Acelerar evaluación proveedores (SCRM) - €30k, 12 semanas
3. Mejorar proceso parcheo (PROTECT) - €15k, 6 semanas
4. Intensificar conciencia (AWARENESS) - €10k, 12 semanas

PARTE 3: REPORTE (SEMANA 7-8)

Paso 3.1: Estructura de Reporte Ejecutivo

DOCUMENTO FORMAL (8-12 páginas):

Página 1: Portada

- Título: "Evaluación de Madurez de Ciberseguridad 2026"
- Fecha
- Logo organizacional
- Clasificación: "Confidencial"
- Versión: 1.0

Página 2: Executive Summary (1 página)

- Posición actual en 5 bullets
- IGM global (%)
- Top 3 riesgos críticos
- Top 3 fortalezas
- 1 recomendación más importante

Páginas 3-4: Metodología (2 páginas)

- Cómo se ejecutó (GQM + PRAGMATIC)
- Respondentes (cuántos, quiénes)
- Limitaciones
- Benchmarking (cómo comparamos)

Páginas 5-8: Análisis Detallado (4 páginas)

- Gráfico radar (IGM por módulo)
- Heatmap (fortalezas vs debilidades)
- Tabla: Hallazgos por módulo (qué está bien, qué no)
- Métricas clave (MTTD, MTTR, MFA %, etc.)

Páginas 9-10: Riesgos Críticos (2 páginas)

- Top 5 riesgos identificados
- Por cada riesgo:
 - Descripción
 - Impacto (qué pasaría si no lo arreglamos)
 - Root cause (por qué existe)
 - Recomendación de remediación
- Presupuesto estimado por riesgo

Página 11: Roadmap de Mejora (1 página)

- 6-12 meses plan (hitos visuales)
- Quick wins (implementables en 3 meses)
- Iniciativas medianas (3-6 meses)
- Iniciativas estratégicas (6-12 meses)

Página 12: Conclusiones (1 página)

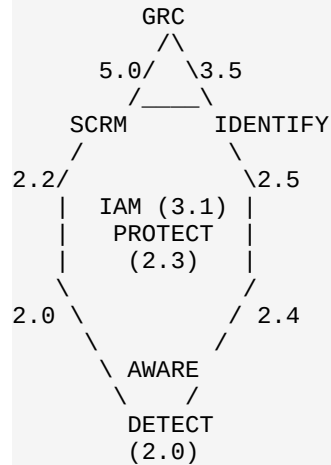
- Resumen de posición
- Llamado a la acción
- Siguiendo revisión planeada
- Contactos

Apéndices:

- Encuesta completa (preguntas y respuestas)
- Datos brutos (responses.xlsx)
- Mapeo a regulaciones (NIS2, GDPR, etc.)
- FAQ (respuestas a preguntas esperadas)

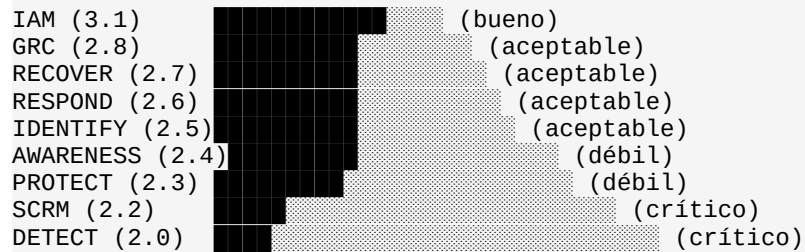
Paso 3.2: Gráficos Recomendados

GRÁFICO 1: Radar Chart (IGM por Módulo)



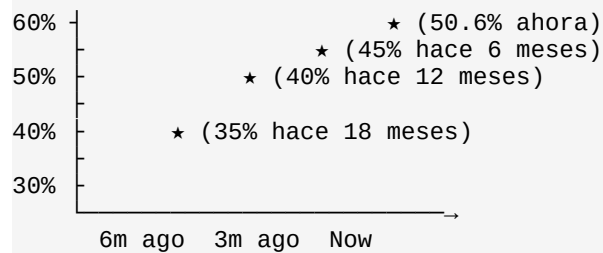
Uso: Mostrar balance de módulos, identificar gaps visualmente.

GRÁFICO 2: Bar Chart (Fortalezas vs Debilidades)



Uso: Mostrar cuáles módulos necesitan mayor inversión.

GRÁFICO 3: Trend (IGM últimos trimestres si aplica)



Uso: Si tienen datos históricos, mostrar mejora/deterioro.

Paso 3.3: Presentación a Board

PRESENTACIÓN EXECUTIVE (20-25 minutos):

Slide 1: Portada (0.5 min)

Slide 2: Posición Actual (2 min)

- └ IGM global en grande (50.6%)
- └ Comparativa vs benchmark sector
- └ 1 dato sorprendente

Slide 3: Módulos Resumen (2 min)

- └ Radar chart (todos 9 módulos)
- └ Señalar rojo/amarillo/verde

Slide 4-5: Top 3 Riesgos Críticos (5 min)

- └ Por riesgo: descripción + impacto + recomendación
- └ Presupuesto asociado
- └ Timeline de remediación

Slide 6: Fortalezas Detectadas (1 min)

- └ "Sobre qué estamos bien construyendo"
- └ Celebrar logros

Slide 7: Roadmap 12 Meses (2 min)

- └ Visualizar hitos
- └ Quick wins vs iniciativas estratégicas

Slide 8: Presupuesto & ROI (2 min)

- └ Inversión recomendada (€X)
- └ ROI esperado (€Y en 3 años)

Slide 9: Recomendaciones (2 min)

- └ 3-5 decisiones clave que requieren votación
- └ "¿Aprobamos presupuesto para SIEM?"

Slide 10: Próximos Pasos (0.5 min)

- └ Cuándo re-evaluamos (anual)
- └ Quién es responsable de cada riesgo
- └ Contacto para preguntas

Q&A (5 min)

PREPARACIÓN DEL PRESENTADOR:

- ✓ Ensayar 3 veces (timing, tono, transiciones)
- ✓ Anticipar preguntas: "¿Somos malos?" (NO, somos honestos)
- ✓ Tener datos de backup (respuestas completas)
- ✓ Documentar decisiones del board (acta)

PARTE 4: BENCHMARKING Y COMPARATIVAS

Benchmarks Sector España 2024-2025

SECTOR FINANCIERO:

- IGM Promedio: 75-80%
- Líderes: 85-90%
- Rezagados: <70%
- Módulos críticos: DETECT, RESPOND, SCRM
- "Vosotros 50.6% vs benchmark 78% = gap de 27 puntos"

SECTOR ENERGÍA/INFRAESTRUCTURA CRÍTICA:

- IGM Promedio: 78-82%
- Líderes: 88-95%
- Rezagados: <75%
- Módulos críticos: RECOVER, SCRM, CONTINUITY
- Más exigentes que financiero

SECTOR TECNOLOGÍA:

- IGM Promedio: 80-85%
- Líderes: 90-98%
- Rezagados: <78%
- Módulos críticos: PROTECT, DETECT, IAM
- Generalmente más maduro

PEQUEÑA EMPRESA (<250 empleados):

- IGM Promedio: 55-65%
- Líderes: 75-85%
- Rezagados: <50%
- "Es normal estar en 50% si eres PYME"
- Focus: GRC, IDENTIFY, IAM, PROTECT

ADMINISTRACIÓN PÚBLICA:

- IGM Promedio: 65-72%
- Líderes: 80-85%
- Rezagados: <60%
- Módulos críticos: GRC (regulación), SCRM
- Presupuesto limitado, cambios lentos

INTERPRETACIÓN:

"Si estamos en percentil 25-50 de sector, es aceptable pero requiere plan.
Si estamos en percentil <25, es preocupante e invita a acción urgente."

PARTE 5: FAQ Y RESPUESTAS ESPERADAS

Preguntas Típicas de Ejecutivos

P1: "¿Estamos en riesgo crítico?"

R1: "IGM 50.6% es 'aceptable pero con oportunidades de mejora'. No estamos en crisis, pero hay 3 riesgos que necesitan atención los próximos 6 meses: SIEM lento (DETECT), parcheo lento (PROTECT), SCRM incompleto (regulatorio)."

P2: "¿Cómo comparamos con competidores?"

R2: "Vs benchmark sector financiero (78%), estamos 27 puntos atrás. Esto es manejable: con inversión focalizada en 3 áreas, alcanzamos 75% en 12 meses."

P3: "¿Cuánto cuesta arreglarlo?"

R3: "Plan integral 12 meses: €150k (herramientas + personal + servicios).
ROI estimado: €4-6M en mitigación de riesgo. Payback: mes 6."

P4: "¿Quién está siendo negligente?"

R4: "No se trata de culpa. Es reflejo de presupuesto/prioridades históricas.
Ahora tenemos clarity, podemos invertir inteligentemente."

P5: "¿Cómo sabemos que estas métricas son correctas?"

R5: "Metodología GQM (trazable a objetivos) + PRAGMATIC (viable en práctica).
Además, resultados alineados con observaciones operacionales (ej: SIEM lento)."

P6: "¿Necesitamos auditoría externa?"

R6: "Recomendación: auditoría de SCRM este año (NIS2 comply). Para resto:
podemos hacer autoevaluación anual + auditoría externa cada 2 años."

P7: "¿Y si los resultados tienen sesgo?"

R7: "Riesgo bajo: múltiples respondentes + sesiones de calibración + validación
con evidencia observable. Además, mejor datos imperfectos que ningún dato."
""

Guía Metodológica Versión 1.0 | Enero 2026 | España